

Ondo Finance Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Dacian

April 18, 2024

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 3

7 Risk Classification 4

8 Protocol Summary 4

9 Attestation 4

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Ondo Finance on Ondo Finance. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated April 18, 2024, was delivered to Ondo Finance, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Ondo Finance or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 9 days, the Cyfrin team conducted an audit on the Ondo Finance code provided by Ondo Finance. The findings consist of 7 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	Ondo Finance
Repository	rwa-internal
Commit	6747ebada1c8...
Audit Timeline	Apr 8th - Apr 18th, 2024
Methods	Manual Review, Stateful Fuzzing

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	7	7	0
Informational	7	2	5
Gas Optimizations	10	3	7
Total	24	12	12

6 Audit Scope

The following contracts were included in the scope for this audit:

```
contracts/ousg/ousgInstantManager.sol
contracts/ousg/rOUSG.sol
contracts/ousg/InvestorBasedRateLimiter.sol
contracts/InstantMintTimeBasedRateLimiter.sol
contracts/kyc/KYCRegistryClientUpgradeable.sol
```

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

Ondo Finance is a Real-World Asset Tokenization protocol which aims to bring institutional-grade investment products onto blockchains.

This audit only concerned:

- `OUSG`, a tokenized wrapper of the Blackrock short-term US Treasuries ETF
- `rOUSG`, a rebalancing wrapper for `OUSG`
- `OUSGInstantManager`, a manager contract that allows users to mint and redeem `OUSG` and `rOUSG`
- a couple of rate-limiting contracts

Users who have satisfied KYC and other applicable regulatory requirements are able to use `OUSGInstantManager` to mint `OUSG`/`rOUSG` in exchange for `USDC`, and to redeem `OUSG`/`rOUSG` to receive `USDC`. `OUSG` and `rOUSG` function as `ERC20` tokens which users can transfer only to other KYC'd users, and mints and redemptions are subject to time-based rate limits.

When users redeem `OUSG`/`rOUSG` via `OUSGInstantManager`, the protocol sources the `USDC` by redeeming Blackrock's `BUIDL` token through its redemption contract, which provides 1:1 `BUIDL:USDC` redemptions.

9 Attestation

Cyfrin attests that it performed a security review of the Ondo Finance code provided by Ondo Finance.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2024-04-18-cyfrin-ondo-finance-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Ondo Finance has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=afb2b5ec00e3753982c339ea59399d087d2978819525c83d81ccc2264f8e4846
F=2024-04-18-cyfrin-ondo-finance-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.